PERFORMANCE WORK STATEMENT (PWS)
DEPARTMENT OF VETERANS AFFAIRS

Office of Management (OM)
Financial Services Center (FSC)

Brand Name or Equal F5 Balancer Replacement with Migration Services and Support and Maintenance

Date: October 16, 2026

VA-27-00017931

PWS Version Number: 1.0

DRAFT

Contents

1.0 BACKGROUND 3
2.0 APPLICABLE DOCUMENTS 3
3.0 SCOPE OF WORK 6
4.0 PERFORMANCE DETAILS 7
4.1 PERFORMANCE PERIOD 7
4.2 PLACE OF PERFORMANCE 8
4.3 TRAVEL 8
5.0 SPECIFIC TASKS AND DELIVERABLES 8
6.0 GENERAL REQUIREMENTS 10
6.1 ENTERPRISE AND IT FRAMEWORK 10
6.1.1 VA TECHNICAL REFERENCE MODEL 10
6.1.2 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM) 10
6.1.3 INTERNET PROTOCOL VERSION 6 (IPV6) 11
6.1.4 TRUSTED INTERNET CONNECTION (TIC) 12
6.1.5 STANDARD COMPUTER CONFIGURATION 12
6.1.6 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM) 13
6.1.7 PROCESS ASSET LIBRARY (PAL) 13
6.1.8 AUTHORITATIVE DATA SOURCES 13
6.1.9 SOCIAL SECURITY NUMBER (SSN) REDUCTION 14
6.1.10 SOFTWARE AND LICENSING REQUIREMENTS 15
6.2 METHOD AND DISTRIBUTION OF DELIVERABLES 15
6.3 SHIPMENT OF HARDWARE OR EQUIPMENT 15
ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED 16
ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE 22

DRAFT

1.0 BACKGROUND

The Department of Veterans Affairs (VA), Office of Management (OM), Financial Services Center (FSC) has a requirement for the replacement of its current F5 load balancers and software to manage and re-distribute (balance) the flow of network traffic through FSC's network data centers located at 1615 Woodward Street, Austin TX, and 5000 Wissahickon Ave, Philadelphia PA. Additionally, the FSC requires migration services and load balancer hardware and software maintenance services to ensure the load balancer solution operates as designed.

FSC's current existing environment has one standalone and two HA pair BIG-IP i5820-DF platforms located in the Austin Enterprise Data Center (AEDC) and the Philadelphia Enterprise Data Center (PEDC). These devices are currently running TMOS v17.5.1.x, utilizing BIG-IP LTM, APM, and FIPS for application delivery and user authentication.

In order to implement this solution, the FSC intends to restrict competition to the F5 manufacturer and its authorized distributors to meet the requirements and time constraints outlined in this PWS, at a fair and reasonable price.

2.0 APPLICABLE DOCUMENTS

In the performance of the tasks associated with this Performance Work Statement, the Contractor shall comply with the following:

1. 44 U.S.C. § 3541-3549, "Federal Information Security Management Act (FISMA) of 2002"
2. "Federal Information Security Modernization Act of 2014"
3. Federal Information Processing Standards (FIPS) Publication 140-2, "Security Requirements for Cryptographic Modules"
4. FIPS Pub 199. "Standards for Security Categorization of Federal Information and Information Systems," February 2004
5. FIPS Pub 200, "Minimum Security Requirements for Federal Information and Information Systems," March 2006
6. FIPS Pub 201-2, "Personal Identity Verification of Federal Employees and Contractors," August 2013
7. 10 U.S.C. § 2224, "Defense Information Assurance Program"
8. 5 U.S.C. § 552a, as amended, "The Privacy Act of 1974"
9. Public Law 109-461, Veterans Benefits, Health Care, and Information Technology Act of 2006, Title IX, Information Security Matters
10. 42 U.S.C. § 2000d "Title VI of the Civil Rights Act of 1964"
11. VA Directive 0710, "Personnel Security and Suitability Program," June 4, 2010, https://www.va.gov/vapubs/index.cfm
12. VA Handbook 0710, "Personnel Security and Suitability Program," May 2, 2016, https://www.va.gov/vapubs/index.cfm

DRAFT

13. VA Directive and Handbook 6102, “Internet/Intranet Services,” August 5, 2019
14. 36 C.F.R. Part 1194 “Information and Communication Technology Standards and Guidelines,” January 18, 2017
15. Office of Management and Budget (OMB) Circular A-130, “Managing Federal Information as a Strategic Resource,” July 28, 2016
16. 32 C.F.R. Part 199, “Civilian Health and Medical Program of the Uniformed Services (CHAMPUS)”
17. NIST SP 800-66 Rev. 1, “An Introductory Resource Guide for Implementing the Health Insurance Portability and Accountability Act (HIPAA) Security Rule,” October 2008
18. Sections 504 and 508 of the Rehabilitation Act (29 U.S.C. § 794d), as amended, January 18, 2017
19. Homeland Security Presidential Directive (12) (HSPD-12), August 27, 2004
20. VA Directive 6500, “VA Cybersecurity Program,” February 24, 2021
21. VA Handbook 6500, “Risk Management Framework for VA Information Systems VA Information Security Program,” February 24, 2021
22. VA Handbook 6500.2, “Management of Breaches Involving Sensitive Personal Information (SPI),” March 12, 2019
23. VA Handbook 6500.5, “Incorporating Security and Privacy into the System Development Lifecycle,” March 22, 2010
24. VA Handbook 6500.6, “Contract Security,” March 12, 2010
25. VA Handbook 6500.8, “Information System Contingency Planning,” April 6, 2011
26. VA Handbook 6500.10, “Mobile Device Security Policy,” February 15, 2018
27. VA Handbook 6500.11, “VA Firewall Configuration,” August 22, 2017
28. OIT Process Asset Library (PAL), https://www.va.gov/process/ . Reference Process Maps at https://www.va.gov/process/maps.asp and Artifact templates at https://www.va.gov/process/artifacts.asp
29. One-VA Technical Reference Model (TRM) (reference at https://www.va.gov/trm/TRMHomePage.aspx)
30. VA Directive 6508, “Implementation of Privacy Threshold Analysis and Privacy Impact Assessment,” October 15, 2014
31. VA Handbook 6508.1, “Procedures for Privacy Threshold Analysis and Privacy Impact Assessment,” July 30, 2015
32. VA Handbook 6510, “VA Identity and Access Management,” January 15, 2016
33. VA Directive and Handbook 6513, “Secure External Connections,” October 12, 2017
34. VA Directive 6300, “Records and Information Management,” September 21, 2018
35. VA Handbook, 6300.1, “Records Management Procedures,“ March 24, 2010
36. NIST SP 800-37 Rev 2, “Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy,” December 2018

DRAFT

37. NIST SP 800-53 Rev. 5, “Security and Privacy Controls for Federal Information Systems and Organizations,” September 23, 2020 (includes updates as of 12/10/2020)
38. VA Directive 0735, “Homeland Security Presidential Directive 12 (HSPD-12) Program,” October 26, 2015
39. VA Handbook 0735, “Homeland Security Presidential Directive 12 (HSPD-12) Program,” March 24, 2014
40. OMB Memorandum 05-24, “Implementation of Homeland Security Presidential Directive (HSPD) 12 – Policy for a Common Identification Standard for Federal Employees and Contractors,” August 5, 2005
41. OMB Memorandum M-19-17, “Enabling Mission Delivery Through Improved Identity, Credential, and Access Management,” May 21, 2019
42. OMB Memorandum, “Guidance for Homeland Security Presidential Directive (HSPD) 12 Implementation,” May 23, 2008
43. Federal Identity, Credential, and Access Management (FICAM) Roadmap and Implementation Guidance, December 2, 2011, (NOTE: Part A of the FICAM Roadmap and Implementation Guidance, v2.0, was replaced in 2015 with an updated Architecture (https://arch.idmanagement.gov/#what-is-the-ficam-architecture)
44. NIST SP 800-116 Rev 1, “Guidelines for the Use of Personal Identity Verification (PIV) Credentials in Facility Access,“ June 2018
45. NIST SP 800-63-3, 800-63A, 800-63B, 800-63C, “Digital Identity Guidelines,” updated March 02, 2020
46. NIST SP 800-157, “Guidelines for Derived PIV Credentials,” December 2014
47. NIST SP 800-164, “Guidelines on Hardware-Rooted Security in Mobile Devices (Draft),” October 2012
48. Draft National Institute of Standards and Technology Interagency Report (NISTIR) 7981, “Mobile, PIV, and Authentication,” March 2014
49. VA Memorandum, VAIQ #7100147, “Continued Implementation of Homeland Security Presidential Directive 12 (HSPD-12),” April 29, 2011 (reference https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514)
50. IAM Identity Management Business Requirements Guidance document, May 2013, (reference Enterprise Architecture Section, PIV/IAM (reference https://www.voa.va.gov/documentlistpublic.aspx?NodeID=514)
51. VA Memorandum “Personal Identity Verification (PIV) Logical Access Policy Clarification,” July 17, 2019, https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896
52. Trusted Internet Connections (TIC) 3.0 Core Guidance Documents, https://www.cisa.gov/publication/tic-30-core-guidance-documents
53. OMB Memorandum M-19-26, “Update to the Trusted Internet Connections (TIC) Initiative,” September 12, 2019
54. OMB Memorandum M-08-23, “Securing the Federal Government’s Domain Name System Infrastructure,” August 22, 2008
55. Sections 524 and 525 of the Energy Independence and Security Act of 2007, (Public Law 110–140), December 19, 2007
56. Section 104 of the Energy Policy Act of 2005, (Public Law 109–58), August 8, 2005

DRAFT

57. Executive Order 13834, “Efficient Federal Operations,” dated May 17, 2018
58. Executive Order 13221, “Energy-Efficient Standby Power Devices,” August 2, 2001
59. VA Directive 0058, “VA Green Purchasing Program,” July 19, 2013
60. VA Handbook 0058, “VA Green Purchasing Program,” July 19, 2013
61. Office of Information Security (OIS) VAIQ #7424808 Memorandum, “Remote Access,” January 15, 2014, https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28
62. Clinger-Cohen Act of 1996, 40 U.S.C. §11101 and §11103
63. “Veteran Focused Integration Process (VIP) Guide 4.0,” January 2021, https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371
64. VA Memorandum “Proper Use of Email and Other Messaging Services,” January 2, 2018, https://www.voa.va.gov/DocumentListPublic.aspx?NodeId=28
65. “DevSecOps Product Line Management Playbook” version 2.0, May 2021, https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946
66. NIST SP 500-267B Revision 1, “USGv6 Profile,” November 2020
67. OMB Memorandum M-21-07, “Completing the Transition to Internet Protocol Version 6 (IPv6),” November 19, 2020
68. Social Security Number (SSN) Fraud Prevention Act of 2017
69. Section 240 of the Consolidated Appropriations Act (CAA) 2018, March 23, 2018

3.0 SCOPE OF WORK

The FSC requires a replacement of its load balancer solution. FSC currently uses F5 load balancers on all of its infrastructure for both on-premises and cloud platforms. The content licenses have come to end of life and end of support. The FSC requires a software that can process data quickly, support higher information exchanges and process greater amounts of AI applications. FSC requires the load balancing software to distribute incoming network traffic across multiple servers to prevent any single server from becoming overloaded and ensure that applications remain accessible to users by providing redundancy and managing failovers. FSC requires greater than the average processing speed based on the volume of data exchange that it is currently designing its infrastructure to handle.

FSC requires current configurations to be migrated to a new standalone and tenant pair of BIG-IP r5920-DFs in a 1:1 manner, anticipated to be on a similar or matching tenant TMOS version. Along with migration services, the FSC requires hardware and software maintenance services throughout the contract period of performance.

The contractor shall provide all equipment, tools, materials, supervision, other items, and non-personal service necessary to provide load balancer hardware replacement as well as migration services, and hardware/software maintenance and support services. All configuration/migration services must be completed and the solution must be operational no later than October 1, 2027.

DRAFT

LINE ITEM	SEWP V CLIN	MPN	DESCRIPTION	QTY
Base Period				
1	V3-F5Networks-F5-BIG-LTM-R5920-DF	F5-BIG-LTM-R5920-DF	BIG-IP Appliance: Local Traffic Manager r5920 FIPS Ready (128G, Dual M.2 SSD) F5 Networks, Inc. - F5-BIG-LTM-R5920-DF	3
2	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM1	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3) F5 Networks, Inc. - F5-SVC-BIG-PRE-L1-3	3
3	V3-F5Networks-F5-ADD-BIG-FB-R5XXX-ZL	F5-ADD-BIG-FB-R5XXX	BIG-IP Add-on: Platform FIPS 140 Ready License (r5XXX series) Perpetual (This item can only be sold as part of a configuration and is not available for individual purchase) F5 Networks, Inc. - F5-ADD-BIG-FB-R5XXX	3
4	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-AS	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
5		F5-ADD-BIG-APMR59XXB	F5 Public Sector Part Number BIG-IP Add-on: Access Policy Manager Module r59XX (Base) Perpetual (This item can only be sold as part of a configuration and is not available for individual purchase) F5 Networks, Inc. - F5-ADD-BIG-APMR59XXB	3
6	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM12	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
7	V3-F5Networks-F5-UPG-SFP28-SR	F5-UPG-SFP28-SR	FIELD UPGRADE: TRANSCEIVER: SFP28, 25GSR SHORT RANGE, 100M, LC, MMF, DDM (RSERIES ONLY) F5 Networks, Inc. - F5-UPG-SFP28-SR	14
8	V3-F5Networks-F5-UPG-AC-R5XXX-ZL	F5-UPG-AC-R5XXX	Field Upgrade: Single 650W AC Power Supply (r5XXX) F5 Networks, Inc. - F5-UPG-AC-R5XXX	3
9	V3-F5Networks-F5-UPG-FB-STICKER-1-NSP	F5-UPG-FB-STICKER-1	Field Upgrade: Full Box FIPS Sticker Kit	3
10	V3-F5Networks-F5-CST-S_ZL	F5-CST-S	Consulting: Standard Hourly (M-F 8AM-6PM, postpaid, Minimum 8 hours)	80
11	V3-F5Networks-F5-CST-P-ZL	F5-CST-P	F5 Networks Consulting Services Premium Hourly - Service	8
Option Period 1				
12	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM1	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3) F5 Networks, Inc. - F5-SVC-BIG-PRE-L1-3	3
13	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM16	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
14	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM5	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
Option Period 2				
15	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM1	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3) F5 Networks, Inc. - F5-SVC-BIG-PRE-L1-3	3
16	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM16	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
17	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM5	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
Option Period 3				
18	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM1	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3) F5 Networks, Inc. - F5-SVC-BIG-PRE-L1-3	3
19	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM16	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
20	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM5	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
Option Period 4				
21	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM1	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3) F5 Networks, Inc. - F5-SVC-BIG-PRE-L1-3	3
22	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM16	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3
23	V3-F5Networks-F5-SVC-BIG-PRE-L1-3-BM5	F5-SVC-BIG-PRE-L1-3	BIG-IP Service: Premium (Level 1-3)	3

DRAFT

4.0 PERFORMANCE DETAILS

4.1 PERFORMANCE PERIOD

The PoP shall be 12 months with four (4) 12-month option periods.

Any work at the Government site shall not take place on Federal holidays or weekends unless directed by the Contracting Officer (CO).

There are eleven (11) Federal holidays set by law (USC Title 5 Section 6103) that VA follows:

Under current definitions, four are set by date:

New Year's Day	January 1
Juneteenth	June 19
Independence Day	July 4
Veterans Day	November 11
Christmas Day	December 25

If any of the above falls on a Saturday, then Friday shall be observed as a holiday. Similarly, if one falls on a Sunday, then Monday shall be observed as a holiday.

The other six are set by a day of the week and month:

Martin Luther King's Birthday	Third Monday in January
Washington's Birthday	Third Monday in February
Memorial Day	Last Monday in May
Labor Day	First Monday in September
Columbus Day	Second Monday in October
Thanksgiving	Fourth Thursday in November

4.2 PLACE OF PERFORMANCE

Tasks under this PWS shall be performed remotely.

4.3 TRAVEL

The Government does not anticipate travel under this effort to perform the tasks associated with this effort. Therefore, any costs associated with travel by the Contractor will not be reimbursed by the Government.

5.0 SPECIFIC TASKS AND DELIVERABLES

The Contractor shall perform the following:

1. The Contractor shall coordinate with the COR and FSC personnel to schedule and conduct a pre-implementation call. This call will allow for introductions and help identify FSC/Contractor expectations and key personnel for a follow-up migration-planning meeting.

   Deliverable:

DRAFT

A. Pre-Implementation Call within three (3) business days after award.

2. The Contractor shall coordinate with the COR and FSC personnel an interactive project design and planning meeting to discuss (and agree upon) the following:
    a. Review of existing infrastructure and network diagrams.
    b. High level plan and design development for approach to project tasks.
    c. Timeline for all standard business hours work and maintenance windows.
    d. F5 software version upgrade and platform migration plan – to include technical planning and pre-requirement gathering as well as the testing/verification standards to be utilized during this engagement. This includes:
        i. Appropriate F5 software version to be used on the new F5 platforms.
        ii. Plan for upgrading in-scope F5 platforms to the desired new F5 software version.
        iii. Plan for F5 platform migration from the existing F5 platforms to the new F5 platforms.
        iv. Review base platform and network requirements as applicable (management address, interfaces, VLANs, Self-IP addresses, routes, etc.).
        v. F5OS partitioning and tenant allocation strategy.

    Deliverable:
    A. Project Design and Planning Meeting within two (2) business days of the Pre-Implementation Call.

3. The Contractor shall coordinate with the FSC Method of Procedure (MoP) documentation. The MoP document shall define the appropriate testing criteria, applicable resources needed for Cutover baseline testing, validation activities prior to and during the maintenance window, and acceptance testing during and following the maintenance window, as well as the actual steps required for the maintenance window itself.

    Deliverable:
    A. Method of Procedure documentation to be executed during each upgrade.

4. Execute plans to upgrade the F5 software version and migrate to the new F5 platforms during agreed-upon scheduled maintenance window(s). It is anticipated that the AEDC will require an estimated four (4) after-hours maintenance window to upgrade the F5 software version and migrate to the new F5 platform, whereas the PEDC will require roughly four (4) standard business hours for migration.

    Deliverable:
    A. Upgrade and migration services upon approval of MoP.

DRAFT

5. Provide dedicated support of upgrade and migration.

   Deliverable:
   A. One (1) business day after each upgrade and migration maintenance window.

6.0 GENERAL REQUIREMENTS

6.1 ENTERPRISE AND IT FRAMEWORK

6.1.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall support the VA enterprise management framework. In association with the framework, the Contractor shall comply with OIT Technical Reference Model (VA TRM). The VA TRM is one component within the overall Enterprise Architecture (EA) that establishes a common vocabulary and structure for describing the information technology used to develop, operate, and maintain enterprise applications. Moreover, the VA TRM, which includes the Standards Profile and Product List, serves as a technology roadmap and tool for supporting OIT. Architecture & Engineering Services (AES) has overall responsibility for the VA TRM.

6.1.2 FEDERAL IDENTITY, CREDENTIAL, AND ACCESS MANAGEMENT (FICAM)

The Contractor shall ensure Commercial Off-The-Shelf (COTS) product(s), software configuration and customization, and/or new software are Personal Identity Verification (PIV) card-enabled by accepting HSPD-12 PIV credentials using VA Enterprise Technical Architecture (ETA), https://www.ea.oit.va.gov/EAOIT/VA_EA/Enterprise_Technical_Architecture.asp, and VA Identity and Access Management (IAM) approved enterprise design and integration patterns, https://www.oit.va.gov/library/recurring/edp/index.cfm. The Contractor shall ensure all Contractor delivered applications and systems comply with the VA Identity, Credential, and Access Management policies and guidelines set forth in VA Handbook 6510 VA Identity and Access Management, VA Handbook 0735 Homeland Security Presidential Directive 12 (HSPD-12) Program, and align with the Federal Identity, Credential, and Access Management Roadmap and Implementation Guidance v2.0.

The Contractor shall ensure all Contractor delivered applications and systems provide user authentication services compliant with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-63-3, VA Handbook 6500 Appendix F, “VA System Security Controls”, and VA IAM enterprise requirements for direct, assertion based authentication, and/or trust based authentication, as determined by the design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV card and/or Common Access Card (CAC), as determined by the business need.

The Contractor shall ensure all Contractor delivered applications and systems conform to the specific Identity and Access Management PIV requirements set forth in the Office

DRAFT

of Management and Budget (OMB) Memoranda M-05-24, M-19-17, and NIST Federal Information Processing Standard (FIPS) 201-2. OMB Memoranda M-05-24 and M-19-17 can be found at: https://www.whitehouse.gov/sites/whitehouse.gov/files/omb/memoranda/2005/m05-24.pdf, and https://www.whitehouse.gov/wp-content/uploads/2019/05/M-19-17.pdf respectively. Contractor delivered applications and systems shall be on the FIPS 201-2 Approved Product List (APL). If the Contractor delivered application and system is not on the APL, the Contractor shall be responsible for taking the application and system through the FIPS 201 Evaluation Program.

The Contractor shall ensure all Contractor delivered applications and systems support:

1. Automated provisioning and are able to use enterprise provisioning service.
2. Interfacing with VA's Master Person Index (MPI) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
3. The VA defined unique identity (Secure Identifier [SEC ID] / Integrated Control Number [ICN]).
4. Multiple authenticators for a given identity and authenticators at every Authenticator Assurance Level (AAL) appropriate for the solution.
5. Identity proofing for each Identity Assurance Level (IAL) appropriate for the solution.
6. Federation for each Federation Assurance Level (FAL) appropriate for the solution, if applicable.
7. Two-factor authentication (2FA) through an applicable design pattern as outlined in VA Enterprise Design Patterns.
8. A Security Assertion Markup Language (SAML) implementation if the solution relies on assertion-based authentication. Additional assertion implementations, besides the required SAML assertion, may be provided as long as they are compliant with NIST SP 800-63-3 guidelines.
9. Authentication/account binding based on trusted Hypertext Transfer Protocol (HTTP) headers if the solution relies on Trust based authentication.
10. Role Based Access Control.
11. Auditing and reporting capabilities.
12. Compliance with VIEWS 00155984, PIV Logical Access Policy Clarification https://www.voa.va.gov/DocumentView.aspx?DocumentID=4896.

The required Assurance Levels for this specific effort are Identity Assurance Level 3, Authenticator Assurance Level 3, and Federation Assurance Level 3.

6.1.3 INTERNET PROTOCOL VERSION 6 (IPV6)

The Contractor solution shall support Internet Protocol Version 6 (IPv6) based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf). IPv6 technology, in accordance with the USGv6 Program (https://www.nist.gov/programs-

projects/usgv6-program/usgv6-revision-1), NIST Special Publication (SP) 500-267B Revision 1 "USGv6 Profile" (https://doi.org/10.6028/NIST.SP.500-267Br1), and NIST SP 800-119 "Guidelines for the Secure Deployment of IPv6" (https://doi.org/10.6028/NIST.SP.800-119), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices shall support native IPv6 and dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g. web, email, DNS, ISP services, etc.) shall support native IPv6 and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall communicate using native IPv6 and dual stack (IPv6 / IPv4) operations.

6.1.4 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (https://www.cisa.gov/publication/tic-30-core-guidance-documents). Any deviations must be approved by the VA TIC 3.0 Working Group at vaoisesatic30team@va.gov.

6.1.5 STANDARD COMPUTER CONFIGURATION

The Contractor IT end user solution that is developed for use on standard VA computers shall be compatible with and be supported on the standard VA operating system, currently Windows 10 (64bit), Edge (Chromium based), and 365 Apps for enterprise. Applications delivered to VA and intended to be deployed to Windows 10 workstations shall be delivered as a signed .msi package with switches for silent and unattended installation and updates shall be delivered in signed .msp file formats for easy deployment using Microsoft Endpoint Configuration Manager (CM) VA's current desktop application deployment tool. Signing of the software code shall be through a vendor provided certificate that is trusted by VA using a code signing authority such as Verizon/Cybertrust or Symantec/VeriSign. The Contractor shall also ensure and certify that their solution functions as expected when used from a standard VA computer, with non-admin, standard user rights that have been configured using the United States Government Configuration Baseline (USGCB) and Defense Information Systems Agency (DISA) Secure Technical Implementation Guide (STIG) specific to the particular client operating system being used.

DRAFT

6.1.6 VETERAN FOCUSED INTEGRATION PROCESS (VIP) AND PRODUCT LINE MANAGEMENT (PLM)

The Contractor shall support VA efforts IAW the updated Veteran Focused Integration Process (VIP) and Product Line Management (PLM). The major focus of the new VIP is on Governance and Reporting and is less prescriptive, with a focus on outcomes and continuous delivery of value. Product Line Management (PLM) is a framework that focuses on delivering functional products that provide the highest priority work to customers while delivering simplified, reliable, and practical solutions to the business, medical staff, and our Veterans. The VIP Guide is a companion guide to the PLM Playbook and can be found at: https://www.voa.va.gov/DocumentView.aspx?DocumentID=4371 and the PLM Playbook can be found at https://www.voa.va.gov/DocumentView.aspx?DocumentID=4946. The PLM Playbook pivots from project-centric to product-centric delivery and contains descriptive practices that focuses on outcomes. The PLM Playbook contains a set of "plays" that implement Development, Security, and Operations (DevSecOps) principles and processes such as automated development, continuous integration/continuous delivery, and release on demand. The PLM Playbook details how product lines implement Lean-Agile principles, methods, practices, and techniques through levels of maturity. VIP and PLM are the authoritative processes that IT projects must follow to ensure development and delivery of IT products.

6.1.7 PROCESS ASSET LIBRARY (PAL)

The Contractor shall perform their duties consistent with the processes defined in the OIT Process Asset Library (PAL). The PAL scope includes the full spectrum of OIT functions and activities, such as VIP project management, operations, service delivery, communications, acquisition, and resource management. PAL serves as an authoritative and informative repository of searchable processes, activities or tasks, roles, artifacts, tools and applicable standards and guides to assist the OIT workforce, Government and Contractor personnel. The Contractor shall follow the PAL processes to ensure compliance with policies and regulations and to meet VA quality standards. The PAL includes the contractor onboarding process consistent with Section 6.2.2 and can be found at https://www.va.gov/PROCESS/artifacts/maps/process_CONB_ext.pdf. The main PAL can be accessed at www.va.gov/process.

6.1.8 AUTHORITATIVE DATA SOURCES

The VA Enterprise Architecture Repository (VEAR) is one component within the overall EA that establishes the common framework for data taxonomy for describing the data architecture used to develop, operate, and maintain enterprise applications. The Contractor shall comply with the department's Authoritative Data Source (ADS) requirement that VA systems, services, and processes throughout the enterprise shall

DRAFT

access VA data solely through official VA ADSs where applicable, see below. The Information Classes which compose each ADS are located in the VEAR, in the Data & Information domain. The Contractor shall ensure that all delivered applications and system solutions support:

1. Interfacing with VA's Master Person Index (MPI) (formerly the Master Veteran Index (MVI)) to provision identity attributes, if the solution relies on VA user identities. MPI is the authoritative source for VA user identity data.
2. Interfacing with Capital Asset Inventory (CAI) to conduct real property record management actions, if the solution relies on real property records data. CAI is the authoritative source for VA real property record management data.
3. Interfacing with electronic Contract Management System (eCMS) for access to contract, contract line item, purchase requisition, offering vendor and vendor, and solicitation information above the micro-purchase threshold, if the solution relies on procurement data. ECMS is the authoritative source for VA procurement actions data.
4. Interfacing with HRSmart Human Resources Information System to conduct personnel action processing, on-boarding, benefits management, and compensation management, if the solution relies on personnel data. HRSmart is the authoritative source for VA personnel information data.
5. Interfacing with Vet360 to access personal contact information, if the solution relies on VA Veteran personal contact information data. Vet360 is the authoritative source for VA Veteran Personal Contact Data.
6. Interfacing with VA/Department of Defense (DoD) Identity Repository (VADIR) for determining eligibility for VA benefits under Title 38, if the solution relies on qualifying active duty military service data. VADIR is the authoritative source for Qualifying Active Duty military service in VA.

6.1.9 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the ICN in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA Master Person Index (MPI) for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

DRAFT

6.1.10 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or integrate with the Contractor's proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.2 METHOD AND DISTRIBUTION OF DELIVERABLES

The Contractor shall deliver documentation in electronic format, unless otherwise directed in Section B of the solicitation/contract. Acceptable electronic media include: Microsoft 365, MS Word 2000/2003/2007/2010/2019, MS Excel 2000/2003/2007/2010/2019, MS PowerPoint 2000/2003/2007/2010/2019, MS Project 2000/2003/2007/2010/2019, MS Access 2000/2003/2007/2010, MS Visio 2000/2002/2003/2007/2010/2019, AutoCAD 2002/2004/2007/2010, and Adobe Postscript Data Format (PDF).

6.3 SHIPMENT OF HARDWARE OR EQUIPMENT

Inspection: Destination
Acceptance: Destination
Free on Board (FOB): Destination

Ship To and Mark For:

	Primary		Alternate
Name:	_____	Name:	_____
Address:	_____	Address:	_____
Voice:	_____	Voice:	_____
Email:	_____	Email:	_____

Special Shipping Instructions:

Prior to shipping, Contractor shall notify Site POCs, by phone followed by email, of all incoming deliveries including line-by-line details for review of requirements. Contractor shall not make any changes to the delivery schedule at the request of Site POC.

Contractors shall coordinate deliveries with Site POCs before shipment of hardware to ensure sites have adequate storage space.

DRAFT

All shipments, either single or multiple container deliveries, shall bear the VA contract number on external shipping labels and associated manifests or packing lists.

Packing Slips/Labels and Lists shall also include the following:

Contract #: _____
Project Description: (e.g. Tier I Lifecycle Refresh)

Total number of Containers: Package ___ of ___. (e.g., Package 1 of 3)

ADDENDUM A – ADDITIONAL VA REQUIREMENTS, CONSOLIDATED

A1.0 Cyber and Information Security Requirements for VA IT Services

The Contractor shall ensure adequate LAN/Internet, data, information, and system security in accordance with VA standard operating procedures and standard PWS language, conditions, laws, and regulations. The Contractor's firewall and web server shall meet or exceed VA minimum requirements for security. All VA data shall be protected behind an approved firewall. Any security violations or attempted violations shall be reported to the VA Program Manager and VA Information Security Officer as soon as possible. The Contractor shall follow all applicable VA policies and procedures governing information security, especially those that pertain to assessment and authorization and continuous monitoring

Contractor supplied equipment, PCs of all types, equipment with hard drives, etc. for contract services must meet all security requirements that apply to Government Furnished Equipment (GFE) and Government Owned Equipment (GOE). Security Requirements include: a) VA Approved Encryption Software must be installed on all laptops or mobile devices before placed into operation, b) Bluetooth equipped devices are prohibited within VA; Bluetooth must be permanently disabled or removed from the device, unless the connection uses FIPS 140-2 (or its successor) validated encryption, c) VA approved anti-virus and firewall software, d) Equipment must meet all VA sanitization requirements and procedures before disposal. The COR, CO, the PM, and the Information Security Officer (ISO) must be notified and verify all security requirements have been adhered to.

Each documented initiative under this contract incorporates VA Handbook 6500.6, "Contract Security," March 12, 2010 by reference as though fully set forth therein. The VA Handbook 6500.6, "Contract Security" shall also be included in every related agreement, contract, or order. The VA Handbook 6500.6, Appendix C, is included in this document as Addendum B.

Training requirements: The Contractor shall complete all mandatory training courses on the current VA training site, the VA Talent Management System (TMS) 2.0, and will be tracked therein. The TMS 2.0 may be accessed at
https://www.tms.va.gov/SecureAuth35/

DRAFT

. If you do not have a TMS 2.0 profile, go to
https://www.tms.va.gov/SecureAuth35/
and click on the "Create New User" link on the TMS 2.0 to gain access.

Contractor employees shall complete a VA Systems Access Agreement if they are provided access privileges as an authorized user of the computer system of VA.

A2.0 VA Enterprise Architecture Compliance

The applications, supplies, and services furnished under this contract must comply with VA Enterprise Architecture (EA), available at http://www.ea.oit.va.gov/index.asp in force at the time of issuance of this contract, including the Program Management Plan and VA's rules, standards, and guidelines in the Technical Reference Model/Standards Profile (TRMSP). VA reserves the right to assess contract deliverables for EA compliance prior to acceptance**.**

A2.1. VA Internet and Intranet Standards

The Contractor shall adhere to and comply with VA Directive 6102 and VA Handbook 6102, Internet/Intranet Services, including applicable amendments and changes, if the Contractor's work includes managing, maintaining, establishing, and presenting information on VA's Internet/Intranet Service Sites. This pertains, but is not limited to: creating announcements; collecting information; databases to be accessed, graphics and links to external sites.

Internet/Intranet Services Directive 6102 is posted at (copy and paste the following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1056&FType=2

Internet/Intranet Services Handbook 6102 is posted at (copy and paste following URL to browser): https://www.va.gov/vapubs/viewPublication.asp?Pub_ID=1055&FType=2

A3.0 Notice of the Federal Accessibility Law Affecting All Information and Communication Technology (ICT) Procurements (Section 508)

On January 18, 2017, the Architectural and Transportation Barriers Compliance Board (Access Board) revised and updated, in a single rulemaking, standards for electronic and information technology developed, procured, maintained, or used by Federal agencies covered by Section 508 of the Rehabilitation Act of 1973, as well as our guidelines for telecommunications equipment and customer premises equipment covered by Section 255 of the Communications Act of 1934. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

A3.1. Section 508 – Information and Communication Technology (ICT) Standards

DRAFT

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: https://www.access-board.gov/guidelines-and-standards/communications-and-it/about-the-ict-refresh/final-rule/text-of-the-standards-and-guidelines. A printed copy of the standards will be supplied upon request.

Federal agencies must comply with the updated Section 508 Standards beginning on January 18, 2018. The Final Rule as published in the Federal Register is available from the Access Board: https://www.access-board.gov/guidelines-and-standards/communications-and-it/about-the-ict-refresh/final-rule.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☒ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

A3.2. Compatibility with Assistive Technology

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

A3.3. Acceptance and Acceptance Testing

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

DRAFT

A4.0 Physical Security & Safety Requirements:

The Contractor and their personnel shall follow all VA policies, standard operating procedures, applicable laws and regulations while on VA property. Violations of VA regulations and policies may result in citation and disciplinary measures for persons violating the law.

1. The Contractor and their personnel shall wear visible identification at all times while they are on the premises.
2. VA does not provide parking spaces at the work site; the Contractor must obtain parking at the work site if needed. It is the responsibility of the Contractor to park in the appropriate designated parking areas. VA will not invalidate or make reimbursement for parking violations of the Contractor under any conditions.
3. Smoking is prohibited inside/outside any building other than the designated smoking areas.
4. Possession of weapons is prohibited.
5. The Contractor shall obtain all necessary licenses and/or permits required to perform the work, with the exception of software licenses that need to be procured from a Contractor or vendor in accordance with the requirements document. The Contractor shall take all reasonable precautions necessary to protect persons and property from injury or damage during the performance of this contract.

A5.0 Confidentiality and Non-Disclosure

The Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations.

The Contractor may have access to Protected Health Information (PHI) and Electronic Protected Health Information (EPHI) that is subject to protection under the regulations issued by the Department of Health and Human Services, as mandated by the Health Insurance Portability and Accountability Act of 1996 (HIPAA); 45 CFR Parts 160 and 164, Subparts A and E, the Standards for Privacy of Individually Identifiable Health Information (“Privacy Rule”); and 45 CFR Parts 160 and 164, Subparts A and C, the Security Standard (“Security Rule”). Pursuant to the Privacy and Security Rules, the Contractor must agree in writing to certain mandatory provisions regarding the use and disclosure of PHI and EPHI.

1. The Contractor will have access to some privileged and confidential materials of VA. These printed and electronic documents are for internal use only, are not to be copied or released without permission, and remain the sole property of VA. Some of these materials are protected by the Privacy Act of 1974 (revised by PL 93-5791) and Title 38. Unauthorized disclosure of Privacy Act or Title 38 covered materials is a criminal offense.
2. The VA CO will be the sole authorized official to release in writing, any data, draft deliverables, final deliverables, or any other written or printed materials pertaining to this contract. The Contractor shall release no information. Any

DRAFT

request for information relating to this contract presented to the Contractor shall be submitted to the VA CO for response.

3. Contractor personnel recognize that in the performance of this effort, Contractor personnel may receive or have access to sensitive information, including information provided on a proprietary basis by carriers, equipment manufacturers and other private or public entities. Contractor personnel agree to safeguard such information and use the information exclusively in the performance of this contract. Contractor shall follow all VA rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations as enumerated in this section and elsewhere in this Contract and its subparts and appendices.
4. Contractor shall limit access to the minimum number of personnel necessary for contract performance for all information considered sensitive or proprietary in nature. If the Contractor is uncertain of the sensitivity of any information obtained during the performance this contract, the Contractor has a responsibility to ask the VA CO.
5. Contractor shall train all of their employees involved in the performance of this contract on their roles and responsibilities for proper handling and nondisclosure of sensitive VA or proprietary information. Contractor personnel shall not engage in any other action, venture or employment wherein sensitive information shall be used for the profit of any party other than those furnishing the information. The sensitive information transferred, generated, transmitted, or stored herein is for VA benefit and ownership alone.
6. Contractor shall maintain physical security at all facilities housing the activities performed under this contract, including any Contractor facilities according to VA-approved guidelines and directives. The Contractor shall ensure that security procedures are defined and enforced to ensure all personnel who are provided access to patient data must comply with published procedures to protect the privacy and confidentiality of such information as required by VA.
7. Contractor must adhere to the following:
    a. The use of “thumb drives” or any other medium for transport of information is expressly prohibited.
    b. Controlled access to system and security software and documentation.
    c. Recording, monitoring, and control of passwords and privileges.
    d. All terminated personnel are denied physical and electronic access to all data, program listings, data processing equipment and systems.
    e. VA, as well as any Contractor (or Subcontractor) systems used to support development, provide the capability to cancel immediately all access privileges and authorizations upon employee termination.
    f. Contractor PM and VA PM are informed within twenty-four (24) hours of any employee termination.
    g. Acquisition sensitive information shall be marked "Acquisition Sensitive" and shall be handled as "For Official Use Only (FOUO)".
    h. Contractor does not require access to classified data.

DRAFT

8. Regulatory standard of conduct governs all personnel directly and indirectly involved in procurements. All personnel engaged in procurement and related activities shall conduct business in a manner above reproach and, except as authorized by statute or regulation, with complete impartiality and with preferential treatment for none. The general rule is to strictly avoid any conflict of interest or even the appearance of a conflict of interest in VA/Contractor relationships.
9. VA Form 0752 shall be completed by all Contractor employees working on this contract, and shall be provided to the CO before any work is performed. In the case that Contractor personnel are replaced in the future, their replacements shall complete VA Form 0752 prior to beginning work.

DRAFT

ADDENDUM B – VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE

APPLICABLE PARAGRAPHS TAILORED FROM: *THE VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE, VA HANDBOOK 6500.6, APPENDIX C, MARCH 12, 2010*

B1. GENERAL

Contractors, Contractor personnel, Subcontractors, and Subcontractor personnel shall be subject to the same Federal laws, regulations, standards, and VA Directives and Handbooks as VA and VA personnel regarding information and information system security.

B2. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

a. A Contractor/Subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees, Subcontractors, and affiliates only to the extent necessary to perform the services specified in the contract, agreement, or task order.

b. All Contractors, Subcontractors, and third-party servicers and associates working with VA information are subject to the same investigative requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for Contractors must be in accordance with VA Directive and Handbook 0710, *Personnel Suitability and Security Program*. The Office for Operations, Security, and Preparedness is responsible for these policies and procedures.

c. Contract personnel who require access to national security programs must have a valid security clearance. National Industrial Security Program (NISP) was established by Executive Order 12829 to ensure that cleared U.S. defense industry contract personnel safeguard the classified information in their possession while performing work on contracts, programs, bids, or research and development efforts. The Department of Veterans Affairs does not have a Memorandum of Agreement with Defense Security Service (DSS). Verification of a Security Clearance must be processed through the Special Security Officer located in the Planning and National Security Service within the Office of Operations, Security, and Preparedness.

d. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practical. If such services are proposed to be performed abroad and are not disallowed by other VA policy or mandates (e.g. Business Associate Agreement, Section 3G), the Contractor/Subcontractor must state where all non-U.S. services are provided and detail a security plan, deemed to be acceptable by VA,

DRAFT

specifically to address mitigation of the resulting problems of communication, control, data protection, and so forth. Location within the U.S. may be an evaluation factor.

e. The Contractor or Subcontractor must notify the CO immediately when an employee working on a VA system or with access to VA information is reassigned or leaves the Contractor or Subcontractor's employ. The CO must also be notified immediately by the Contractor or Subcontractor prior to an unfriendly termination.

B3. VA INFORMATION CUSTODIAL LANGUAGE

1. Information made available to the Contractor or Subcontractor by VA for the performance or administration of this contract or information developed by the Contractor/Subcontractor in performance or administration of the contract shall be used only for those purposes and shall not be used in any other way without the prior written agreement of VA. This clause expressly limits the Contractor/Subcontractor's rights to use data as described in Rights in Data - General, FAR 52.227-14(d) (1).

2. VA information should not be co-mingled, if possible, with any other data on the Contractors/Subcontractor's information systems or media storage systems in order to ensure VA requirements related to data protection and media sanitization can be met. If co-mingling must be allowed to meet the requirements of the business need, the Contractor must ensure that VA information is returned to VA or destroyed in accordance with VA's sanitization requirements. VA reserves the right to conduct on-site inspections of Contractor and Subcontractor IT resources to ensure data security controls, separation of data and job duties, and destruction/media sanitization procedures are in compliance with VA directive requirements.

3. Prior to termination or completion of this contract, Contractor/Subcontractor must not destroy information received from VA, or gathered/created by the Contractor in the course of performing this contract without prior written approval by VA. Any data destruction done on behalf of VA by a Contractor/Subcontractor must be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, *Records and Information Management* and its Handbook 6300.1 *Records Management Procedures*, applicable VA Records Control Schedules, and VA Handbook 6500.1, *Electronic Media Sanitization*. Self-certification by the Contractor that the data destruction requirements above have been met must be sent to the VA CO within 30 days of termination of the contract.

4. The Contractor/Subcontractor must receive, gather, store, back up, maintain, use, disclose and dispose of VA information only in compliance with the terms of the contract and applicable Federal and VA information confidentiality and security laws, regulations and policies. If Federal or VA information confidentiality and security laws, regulations and policies become applicable to VA information or information systems after execution of the contract, or if NIST issues or updates applicable FIPS or Special Publications (SP) after execution of this contract, the parties agree to negotiate in good faith to implement the information confidentiality and security laws, regulations and policies in this contract.

DRAFT

5. The Contractor/Subcontractor shall not make copies of VA information except as authorized and necessary to perform the terms of the agreement or to preserve electronic information stored on Contractor/Subcontractor electronic storage media for restoration in case any electronic equipment or data used by the Contractor/Subcontractor needs to be restored to an operating state. If copies are made for restoration purposes, after the restoration is complete, the copies must be appropriately destroyed.

6. If VA determines that the Contractor has violated any of the information confidentiality, privacy, and security provisions of the contract, it shall be sufficient grounds for VA to withhold payment to the Contractor or third party or terminate the contract for default or terminate for cause under Federal Acquisition Regulation (FAR) part 12.

7. If a VHA contract is terminated for cause, the associated Business Associate Agreement (BAA) must also be terminated and appropriate actions taken in accordance with VHA Directive 1605.05, *Business Associate Agreements*. Absent an agreement to use or disclose protected health information, there is no business associate relationship.

8. The Contractor/Subcontractor must store, transport, or transmit VA sensitive information in an encrypted form, using VA-approved encryption tools that are, at a minimum, FIPS 140-2 validated.

9. The Contractor/Subcontractor's firewall and Web services security controls, if applicable, shall meet or exceed VA minimum requirements. VA Configuration Guidelines are available upon request.

10. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the Contractor/Subcontractor may use and disclose VA information only in two other situations: (i) in response to a qualifying order of a court of competent jurisdiction, or (ii) with VA prior written approval. The Contractor/Subcontractor must refer all requests for, demands for production of, or inquiries about, VA information and information systems to the VA CO for response.

11. Notwithstanding the provision above, the Contractor/Subcontractor shall not release VA records protected by Title 38 U.S.C. 5705, confidentiality of medical quality assurance records and/or Title 38 U.S.C. 7332, confidentiality of certain health records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse, or infection with human immunodeficiency virus. If the Contractor/Subcontractor is in receipt of a court order or other requests for the above-mentioned information, that Contractor/Subcontractor shall immediately refer such court orders or other requests to the VA CO for response.

12. For service that involves the storage, generating, transmitting, or exchanging of VA sensitive information but does not require Assessment and Authorization (A&A) or a Memorandum of Understanding-Interconnection Security Agreement (MOU-ISA) for

DRAFT

system interconnection, the Contractor/Subcontractor must complete a Contractor Security Control Assessment (CSCA) on a yearly basis and provide it to the COR.

B4. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

1. Information systems that are designed or developed for or on behalf of VA at non-VA facilities shall comply with all VA directives developed in accordance with FISMA, HIPAA, NIST, and related VA security and privacy control requirements for Federal information systems. This includes standards for the protection of electronic PHI, outlined in 45 C.F.R. Part 164, Subpart C, information and system security categorization level designations in accordance with FIPS 199 and FIPS 200 with implementation of all baseline security controls commensurate with the FIPS 199 system security categorization (reference VA Handbook 6500, *Risk Management Framework for VA Information Systems – Tier 3: VA Information Security Program*, and the TIC Reference Architecture). During the development cycle a Privacy Impact Assessment (PIA) must be completed, provided to the COR, and approved by the VA Privacy Service in accordance with Directive 6508, *Implementation of Privacy Threshold Analysis and Privacy Impact Assessment.*

2. The Contractor/Subcontractor shall certify to the COR that applications are fully functional and operate correctly as intended on systems using the VA Federal Desktop Core Configuration (FDCC), and the common security configuration guidelines provided by NIST or VA. This includes Internet Explorer 11 configured to operate on Windows 10 and future versions, as required.

3. The standard installation, operation, maintenance, updating, and patching of software shall not alter the configuration settings from the VA approved and FDCC configuration. Information technology staff must also use the Windows Installer Service for installation to the default “program files” directory and silently install and uninstall.

4. Applications designed for normal end users shall run in the standard user context without elevated system administration privileges.

5. The security controls must be designed, developed, approved by VA, and implemented in accordance with the provisions of VA security system development life cycle as outlined in NIST Special Publication 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*, VA Handbook 6500, *Risk Management Framework for VA Information Systems – Tier 3: VA Information Security Program* and VA Handbook 6500.5, *Incorporating Security and Privacy in System Development Lifecycle*.

6. The Contractor/Subcontractor is required to design, develop, or operate a System of Records Notice (SOR) on individuals to accomplish an agency function subject to the Privacy Act of 1974, (as amended), Public Law 93-579, December 31, 1974 (5 U.S.C. 552a) and applicable agency regulations. Violation of the Privacy Act may involve the imposition of criminal and civil penalties.

DRAFT

7. The Contractor/Subcontractor agrees to:

a. Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function when the contract specifically identifies:

i. The Systems of Records (SOR); and

ii. The design, development, or operation work that the Contractor/Subcontractor is to perform;

b. Include the Privacy Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the proposed subcontract requires the redesign, development, or operation of a SOR on individuals that is subject to the Privacy Act; and

c. Include this Privacy Act clause, including this subparagraph (c), in all subcontracts awarded under this contract which requires the design, development, or operation of such a SOR.

8. In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a SOR on individuals to accomplish an agency function, and criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a SOR on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a SOR on individuals to accomplish an agency function, the Contractor/Subcontractor is considered to be an employee of the agency.

a. “Operation of a System of Records” means performance of any of the activities associated with maintaining the SOR, including the collection, use, maintenance, and dissemination of records.

b. “Record” means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and contains the person’s name, or identifying number, symbol, or any other identifying particular assigned to the individual, such as a fingerprint or voiceprint, or a photograph.

c. “System of Records” means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

9. The vendor shall ensure the security of all procured or developed systems and technologies, including their subcomponents (hereinafter referred to as “Systems”),

DRAFT

throughout the life of this contract and any extension, warranty, or maintenance periods. This includes, but is not limited to workarounds, patches, hot fixes, upgrades, and any physical components (hereafter referred to as Security Fixes) which may be necessary to fix all security vulnerabilities published or known to the vendor anywhere in the Systems, including Operating Systems and firmware. The vendor shall ensure that Security Fixes shall not negatively impact the Systems.

10. The vendor shall notify VA within 24 hours of the discovery or disclosure of successful exploits of the vulnerability which can compromise the security of the Systems (including the confidentiality or integrity of its data and operations, or the availability of the system). Such issues shall be remediated as quickly as is practical**,** based upon the severity of the incident.

11. When the Security Fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the vendor will provide written notice to VA that the patch has been validated as not affecting the Systems within 10 working days. When the vendor is responsible for operations or maintenance of the Systems, they shall apply the Security Fixes based upon the severity of the incident.

12. All other vulnerabilities shall be remediated as specified in this paragraph in a timely manner based on risk, but within 60 days of discovery or disclosure. Exceptions to this paragraph (e.g. for the convenience of VA) shall only be granted with approval of the CO and the VA Assistant Secretary for Office of Information and Technology.

B5. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE, OR USE

a. For information systems that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities, Contractors/Subcontractors are fully responsible and accountable for ensuring compliance with all HIPAA, Privacy Act, FISMA, NIST, FIPS, and VA security and privacy directives and handbooks. This includes conducting compliant risk assessments, routine vulnerability scanning, system patching and change management procedures, and the completion of an acceptable contingency plan for each system. The Contractor's security control procedures must be equivalent, to those procedures used to secure VA systems. A Privacy Impact Assessment (PIA) must also be provided to the COR and approved by VA Privacy Service prior to operational approval. All external Internet connections to VA network involving VA information must be in accordance with the TIC Reference Architecture and reviewed and approved by VA prior to implementation. For Cloud Services hosting, the Contractor shall also ensure compliance with the Federal Risk and Authorization Management Program (FedRAMP).

b. Adequate security controls for collecting, processing, transmitting, and storing of Personally Identifiable Information (PII), as determined by the VA Privacy Service, must be in place, tested, and approved by VA prior to hosting, operation, maintenance, or use of the information system, or systems by or on behalf of VA. These security controls are

DRAFT

to be assessed and stated within the PIA and if these controls are determined not to be in place, or inadequate, a Plan of Action and Milestones (POA&M) must be submitted and approved prior to the collection of PII.

c. Outsourcing (Contractor facility, Contractor equipment or Contractor staff) of systems or network operations, telecommunications services, or other managed services requires A&A of the Contractor's systems in accordance with VA Handbook 6500.3, *Assessment, Authorization and Continuous Monitoring of VA Information Systems* and/or the VA OCS Certification Program Office. Government-owned (Government facility or Government equipment) Contractor-operated systems, third party or business partner networks require memorandums of understanding and interconnection security agreements (MOU-ISA) which detail what data types are shared, who has access, and the appropriate level of security controls for all systems connected to VA networks.

d. The Contractor/Subcontractor's system must adhere to all FISMA, FIPS, and NIST standards related to the annual FISMA security controls assessment and review and update the PIA. Any deficiencies noted during this assessment must be provided to the VA CO and the ISO for entry into the VA POA&M management process. The Contractor/Subcontractor must use the VA POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies must be corrected within the timeframes approved by the Government. Contractor/Subcontractor procedures are subject to periodic, unannounced assessments by VA officials, including the VA Office of Inspector General. The physical security aspects associated with Contractor/Subcontractor activities must also be subject to such assessments. If major changes to the system occur that may affect the privacy or security of the data or the system, the A&A of the system may need to be reviewed, retested and re-authorized per VA Handbook 6500.3. This may require reviewing and updating all of the documentation (PIA, System Security Plan, and Contingency Plan). The Certification Program Office can provide guidance on whether a new A&A would be necessary.

e. The Contractor/Subcontractor must conduct an annual self-assessment on all systems and outsourced services as required. Both hard copy and electronic copies of the assessment must be provided to the COR. The Government reserves the right to conduct such an assessment using Government personnel or another Contractor/Subcontractor. The Contractor/Subcontractor must take appropriate and timely action (this can be specified in the contract) to correct or mitigate any weaknesses discovered during such testing, generally at no additional cost.

f. VA prohibits the installation and use of personally owned or Contractor/Subcontractor owned equipment or software on the VA network. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW, or contract. All of the security controls required for Government furnished equipment (GFE) must be utilized in approved other equipment (OE) and must be funded by the owner of the equipment. All remote systems

DRAFT

must be equipped with, and use, a VA-approved antivirus (AV) software and a personal (host-based or enclave based) firewall that is configured with a VA approved configuration. Software must be kept current, including all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-viral software and the firewall on the non-VA owned OE.

g. All electronic storage media used on non-VA leased or non-VA owned IT equipment that is used to store, process, or access VA information must be handled in adherence with VA Handbook 6500.1, *Electronic Media Sanitization* upon: (i) completion or termination of the contract or (ii) disposal or return of the IT equipment by the Contractor/Subcontractor or any person acting on behalf of the Contractor/Subcontractor, whichever is earlier. Media (hard drives, optical disks, CDs, back-up tapes, etc.) used by the Contractors/Subcontractors that contain VA information must be returned to VA for sanitization or destruction or the Contractor/Subcontractor must self-certify that the media has been disposed of per 6500.1 requirements. This must be completed within 30 days of termination of the contract.

h. Bio-Medical devices and other equipment or systems containing media (hard drives, optical disks, etc.) with VA sensitive information must not be returned to the vendor at the end of lease, for trade-in, or other purposes. The options are:

1) Vendor must accept the system without the drive;

2) VA's initial medical device purchase includes a spare drive which must be installed in place of the original drive at time of turn-in; or

3) VA must reimburse the company for media at a reasonable open market replacement cost at time of purchase.

4) Due to the highly specialized and sometimes proprietary hardware and software associated with medical equipment/systems, if it is not possible for VA to retain the hard drive, then;

a) The equipment vendor must have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact; and

b) Any fixed hard drive on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be preapproved and described in the purchase order or contract.

DRAFT

c) A statement needs to be signed by the Director (System Owner) that states that the drive could not be removed and that (a) and (b) controls above are in place and completed. The ISO needs to maintain the documentation.

B6. SECURITY INCIDENT INVESTIGATION

a. The term “security incident” means an event that has, or could have, resulted in unauthorized access to, loss or damage to VA assets, or sensitive information, or an action that breaches VA security procedures. The Contractor/Subcontractor shall immediately notify the COR and simultaneously, the designated ISO and Privacy Officer for the contract of any known or suspected security/privacy incidents, or any unauthorized disclosure of sensitive information, including that contained in system(s) to which the Contractor/Subcontractor has access.

b. To the extent known by the Contractor/Subcontractor, the Contractor/Subcontractor’s notice to VA shall identify the information involved, the circumstances surrounding the incident (including to whom, how, when, and where the VA information or assets were placed at risk or compromised), and any other information that the Contractor/Subcontractor considers relevant.

c. With respect to unsecured protected health information, the business associate is deemed to have discovered a data breach when the business associate knew or should have known of a breach of such information. Upon discovery, the business associate must notify the covered entity of the breach. Notifications need to be made in accordance with the executed business associate agreement.

d. In instances of theft or break-in or other criminal activity, the Contractor/Subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG and Security and Law Enforcement. The Contractor, its employees, and its Subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor/Subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

B7. LIQUIDATED DAMAGES FOR DATA BREACH

a. Consistent with the requirements of 38 U.S.C. §5725, a contract may require access to sensitive personal information. If so, the Contractor is liable to VA for liquidated damages in the event of a data breach or privacy incident involving any SPI the Contractor/Subcontractor processes or maintains under this contract. However, it is the policy of VA to forgo collection of liquidated damages in the event the Contractor provides payment of actual damages in an amount determined to be adequate by the agency.

DRAFT

b. The Contractor/Subcontractor shall provide notice to VA of a “security incident” as set forth in the Security Incident Investigation section above. Upon such notification, VA must secure from a non-Department entity or the VA Office of Inspector General an independent risk analysis of the data breach to determine the level of risk associated with the data breach for the potential misuse of any sensitive personal information involved in the data breach. The term 'data breach' means the loss, theft, or other unauthorized access, or any access other than that incidental to the scope of employment, to data containing sensitive personal information, in electronic or printed form, that results in the potential compromise of the confidentiality or integrity of the data. Contractor shall fully cooperate with the entity performing the risk analysis. Failure to cooperate may be deemed a material breach and grounds for contract termination.

c. Each risk analysis shall address all relevant information concerning the data breach, including the following:

1) Nature of the event (loss, theft, unauthorized access);
2) Description of the event, including:

a) date of occurrence;

b) data elements involved, including any PII, such as full name, social security number, date of birth, home address, account number, disability code;

3) Number of individuals affected or potentially affected;

4) Names of individuals or groups affected or potentially affected;

5) Ease of logical data access to the lost, stolen or improperly accessed data in light of the degree of protection for the data, e.g., unencrypted, plain text;

6) Amount of time the data has been out of VA control;

7) The likelihood that the sensitive personal information will or has been compromised (made accessible to and usable by unauthorized persons);

8) Known misuses of data containing sensitive personal information, if any;

9) Assessment of the potential harm to the affected individuals;

10) Data breach analysis as outlined in 6500.2 Handbook, *Management of Breaches Involving Sensitive Personal Information*, as appropriate; and

11) Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive personal information that may have been compromised.

DRAFT

d. Based on the determinations of the independent risk analysis, the Contractor shall be responsible for paying to VA liquidated damages in the amount of $37.50 per affected individual to cover the cost of providing credit protection services to affected individuals consisting of the following:

1) Notification;
2) One year of credit monitoring services consisting of automatic daily monitoring of at least 3 relevant credit bureau reports;
3) Data breach analysis;
4) Fraud resolution services, including writing dispute letters, initiating fraud alerts and credit freezes, to assist affected individuals to bring matters to resolution;
5) One year of identity theft insurance with $20,000.00 coverage at $0 deductible; and
6) Necessary legal expenses the subjects may incur to repair falsified or damaged credit records, histories, or financial affairs.

B8. SECURITY CONTROLS COMPLIANCE TESTING

On a periodic basis, VA, including the Office of Inspector General, reserves the right to evaluate any or all of the security controls and privacy practices implemented by the Contractor under the clauses contained within the contract. With 10 working-day's notice, at the request of the Government, the Contractor must fully cooperate and assist in a Government-sponsored security controls assessment at each location wherein VA information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of VA, including those initiated by the Office of Inspector General. The Government may conduct a security control assessment on shorter notice (to include unannounced assessments) as determined by VA in the event of a security incident or at any other time.

B9. TRAINING

a. All Contractor employees and Subcontractor employees requiring access to VA information and VA information systems shall complete the following before being granted access to VA information and its systems:

1) Sign and acknowledge (either manually or electronically) understanding of and responsibilities for compliance with the VA Information Security Rules of Behavior, relating to access to VA information and information systems;

2) Successfully complete the VA Privacy and Information Security Awareness and Rules of Behavior course (TMS 2.0 # VA 10176) and complete this required privacy and information security training annually;

DRAFT

3) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system access [to be defined by the VA program official and provided to the CO for inclusion in the solicitation document – e.g., any role-based information security training required in accordance with NIST Special Publication 800-16, Information Technology Security Training Requirements.]

b. The Contractor shall provide to the CO and/or the COR a copy of the training certificates and certification of signing the Contractor Rules of Behavior for each applicable employee within 2 days of the initiation of the contract and annually thereafter, as required.

c. Failure to complete the mandatory annual training and electronically sign the Rules of Behavior annually, within the timeframe required, is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the training and documents are complete.

DRAFT

Notes to the Contracting Officer

(This section to be removed from PWS before solicitation)

TYPE OF CONTRACT(S)

(Choose the type of contract that applies by selecting the checkbox, or, if a hybrid, select all that apply)

- ☒ Firm Fixed Price
- ☐ Cost Reimbursement
- ☐ Labor-Hour
- ☐ Time-and-Materials
- ☐ Other _____

SCHEDULE FOR DELIVERABLES

Note: Days used in the table below refer to calendar days unless otherwise stated. Deliverables with due dates falling on a weekend or holiday shall be submitted the following Government work day after the weekend or holiday.

(Indicate delivery dates in terms of number of days after (DAC) award. If a deliverable is requested in draft, and then final submission-the deliverable line item is complete, no further update can be requested. Continued reporting should be a separate line item. A Mark For and Ship To address (including Inspection/Acceptance requirements) must be provided for all hardware deliverables. Electronic submission of S/W or paper deliverables should be the norm unless otherwise stated. Email addresses must be provided. Although email addresses are provided below for all POC's, table must be clear as to who receives the deliverables.)

Task	Deliverable ID	Deliverable Description
5.1.1	A	**Contractor Project Management Plan** Due Thirty (30) days after contract (DAC) and updated monthly thereafter. Electronic submission to: VA PM, COR, CO. Inspection: destination Acceptance: destination
5.1.2	A	***<Weekly or Monthly>*** **Progress Report** Due the fifth day of each month throughout the period of performance (PoP). Electronic submission to: VA PM, COR, CO Inspection: destination Acceptance: destination

DRAFT

Task	Deliverable ID	Deliverable Description
5.2	*A*	***Title (ex. Test Plan)*** *Ex. Draft plan is due 30 DAC; Final plan is due five (5) days after receipt of Government comments.* *Electronic submission to: VA PM, COR, CO, list others as necessary* *Inspection: (select one) origin/destination* *Acceptance: (select one) origin/destination*
5.2	*B*	***Title (ex. Test Plan, Hard Copy)*** *Ex. Final plan is due five (5) days after receipt of Government comments, in hard copy.* *Name and title* *Delivery Address:* *Inspection: (select one) origin/destination* *Acceptance: (select one) origin/destination* *FOB: (select one) origin/destination* *(see Special Shipping Instructions)*
6.2.2	A	**Contractor Staff Roster** Due 3 days after contract award and updated throughout the PoP. Electronic submission to: VA PM, COR, CO. Inspection: destination Acceptance: destination
6.7	A	**Master Delivery Schedule** Initial due at Shipment/Delivery Kickoff Meeting, Updates due 5 days after Shipment/Delivery Kickoff Meeting and updated at each delivery Electronic submission to: VA PM, COR, CO, Facility CIO, Implementation Manager, Delivery Date Coordinator. Inspection: destination Acceptance: destination
6.7	B	**Shipment/Delivery Weekly Progress Report** Due 5 days after Shipment/Delivery Kickoff Meeting and updated Weekly Electronic submission to: VA PM, COR, CO, Facility CIO, Implementation Manager, Delivery Date Coordinator. Inspection: destination Acceptance: destination

DRAFT

SOFTWARE AND LICENSING REQUIREMENTS (SECTION 6.1.10)

a. The Governing Law Clause, as typical, Sections B.1 and B.2

B.1 GOVERNING LAW
B.2 SOFTWARE LICENSE, MAINTENANCE, AND TECHNICAL SUPPORT (also to be included as typically)

(1). Definitions….

(2). Software License….
(3). Software Maintenance and Technical Support….
(4). Disabling Software Code….
(5). Manuals and Publications…

b. Price Schedule Language in the Solicitation / Contract (Section B)

Any resulting contract will be awarded on a firm-fixed-price basis as defined by Federal Acquisition Regulation Subpart 16.202. Accordingly, the Contractor shall ensure that any and all costs associated with the Contractor's proposed application(s), software products, software solution, and/or system, shall be included in the Contractor's proposed firm-fixed price, and shall serve as the Contractor's firm-fixed price for the life of any resulting contract. No additional costs or fees relative to the Contractor's proposed application(s), software products, software solution, and/or system including, but not limited to, licensing costs and any associated licensing maintenance required for the development, delivery, integration, operation, and/or maintenance of the Contractor's proposed solution will be allowed, accepted, and/or paid by the Government.

c. Proposal/Quote Submission Instructions Language

Any resulting contract will be awarded on a firm-fixed-price basis as defined by Federal Acquisition Regulation Subpart 16.202. Accordingly, the Offeror shall ensure that any and all costs associated with the Offeror's proposed application(s), software products, software solution, and/or system, shall be included in the Offeror's proposed firm-fixed price, and shall serve as the Offeror's firm-fixed price for the life of any resulting contract. No additional costs or fees relative to the Offeror's proposed application(s), software products, software solution, and/or system including, but not limited to, licensing costs and any associated licensing maintenance required for the development, delivery, integration, operation, and/or maintenance of the Offeror's proposed solution will be allowed, accepted, and/or paid by the Government.

INFORMATION TECHNOLOGY USING ENERGY-EFFICIENT PRODUCTS

As prescribed in 23.705(b)(1), insert the following clauses (**unless an exception applies in accordance with** 23.704(a)**:**

1. **Clause 52.223–13** when acquiring **imaging equipment**. (e.g. Printer, Copier, Multi-Function Device, Scanner, Digital Duplicator)

DRAFT

2. **Clause 52.223–14** when acquiring **Televisions**. (e.g. TV, Hospital Grade TV)
3. **Clause 52.223-16** when acquiring **Personal Computer Products**. (Desktop, Notebook, Monitors, Integrated Desktop Computer, Workstation, Thin Client, Tablet/Slate, Signage Display)

EXEMPTION INFORMATION-(23.704 Electronic products environmental assessment tool)

(a)(1) *General*. As required by E.O.s 13423 and 13514, agencies, when acquiring an electronic product to meet their requirements, shall meet at least 95 percent of those requirements with Electronic Product Environmental Assessment Tool (EPEAT®)-registered electronic products, unless—

1. (i) There is no EPEAT® standard for such product;
2. (ii) No EPEAT®-registered product meets agency requirements; or
3. (iii) The agency head has provided an exemption in accordance with 23.105.)

d. ENERGY STAR - IF ACQUIRING ENERGY STAR PRODUCTS

Energy Efficiency in Energy Consuming Products - Energy Star

As prescribed in 23.206, insert the following clauses (**unless an exception applies in accordance with** 23.204)**:**

1. 52.223-15 Energy Efficiency in Energy-Consuming Products

(EXEMPTION INFORMATION- 23.204 Procurement exemptions)

An agency is not required to procure an ENERGY STAR® or FEMP-designated product if the head of the agency determines in writing that—

(a) No ENERGY STAR® or FEMP-designated product is reasonably available that meets the functional requirements of the agency; or

(b) No ENERGY STAR® or FEMP-designated product is cost effective over the life of the product taking energy cost savings into account.)

e. Federal Energy Management Program (FEMP)- IF ACQUIRING FEMP PRODUCTS

DRAFT

Energy Efficiency in Energy Consuming Products - FEMP

As prescribed in 23.206, insert the following clauses (**unless an exception applies in accordance with** 23.204**):**

1. 52.223-15 Energy Efficiency in Energy-Consuming Products

(EXEMPTION INFORMATION: 23.204 Procurement exemptions)

An agency is not required to procure an ENERGY STAR® or FEMP-designated product if the head of the agency determines in writing that—
(a) No ENERGY STAR® or FEMP-designated product is reasonably available that meets the functional requirements of the agency; or
(b) No ENERGY STAR® or FEMP-designated product is cost effective over the life of the product taking energy cost savings into account.)

SOLICITATION INSTRUCTIONS FOR INFORMATION TECHNOLOGY USING ENERGY-EFFICIENT PRODUCTS

Response Instructions: Offerors shall provide with its quote/proposal evidence of product registration/qualification/designation for EPEAT, Energy Star, and FEMP respectively for any and all proposed products certifying that the proposed product(s) as of the date of the submission of the quote/proposal are registered/qualified/designated as required in the form of screenshots from the associated website. The Offeror shall include in the screenshots submitted, the EPEAT-registered product(s) by manufacturer, model name, and model number to be supplied under this contract, and shall specify the EPEAT level rating (bronze, silver, or gold) for each product. The Offeror shall include in the screenshots submitted, the Energy Star qualified product(s) by manufacturer, model name, and model number to be supplied under this contract, and shall provide evidence of Energy Star qualification for each product. Offerors shall include in the screenshots submitted the FEMP-designated product(s) by brand, model name, and model number to be supplied under this contract. Additionally, the Offeror's quote/proposal shall explicitly self-certify that that the products proposed meet the required EPEAT level rating, Energy Star, or FEMP registration/qualification/designation respectively. Failure to include the requisite evidence and Offeror self-certification may render the Offeror's quote Unacceptable and thus, ineligible for award.

GRAY MARKET GOODS

<If the requiring activity is procuring Information Technology Products (applicable to the work being performed and/or the solution requires) and the CO has determined that clauses 852.212-72 "Gray Market and Counterfeit Items" and/or 852.212-73 "Gray Market and Counterfeit Items-Information Technology (IT) Maintenance Allowing Other-than-New Parts" are to be included in the

DRAFT

contract (as prescribed in 812.301(g) and 812.301(h) respectively), the following shall be included in the Solicitation's Response Instructions to ensure that the Offeror is an authorized reseller and will not provide gray market or counterfeit products or parts>

Response Instructions: Offerors shall provide an authorization letter or other means of verification from the Original Equipment Manufacturer (OEM) confirming it is an authorized dealer, authorized distributor, or authorized reseller for the proposed equipment/system in accordance with VA Acquisition Regulation (VAAR) 852.212-72 and 852.212-73. Additionally, the Offeror's quote/proposal shall explicitly self-certify that it will not provide Gray Market Goods and/or Counterfeit Items, as defined by VA Acquisition Regulation (VAAR) 852.212-72 and 852.212-73, and that it has the level of certification/specialization, as required by the OEM(s). Failure to include the requisite OEM letter(s)/documentation and Offeror self-certification may render the Offeror's quote Unacceptable and thus, ineligible for award.

POINTS OF CONTACT

(Identify POCs for this effort for distribution of deliverables)

VA Program Manager:
Name:
Address:
Voice:
Email:

Contracting Officer's Representative:
Name:
Address:
Voice:
Email:

Contracting Officer:
Name:
Address:
Voice:
Email:

ADDITIONAL ITEMS

SPECIAL INSTRUCTIONS/REMARKS

SPECIAL CLAUSES, ETC. TO BE INCLUDED IN THE SOLICITATION

DRAFT

☐ Transition clause required? (Insert FAR clause, Continuity of Services, FAR 52.237-3)
☐ Intellectual Property/Technical Data Rights Clause required?
☐ OCI Clause required?
☐ Government Furnished Material/Equipment: CO should add a special clause to the contract citing the Title of the material/equipment, Identifier (Serial Number), Quantity, Purpose, and Date required by Contractor.
☐ BAA required **for an OIT Contract on behalf of VHA?**

If the answer to Question 4 of the Security Checklist is a "yes" and the Contractor will provide a service, function, or activity **to OIT, on behalf of VHA**, then it must be determined if protected health information (PHI) is disclosed or accessed, if so, a BAA is required. (The "Decision Tree for Business Associate Agreements" can be used by the requiring activity (with help from their OIT Privacy Officer [Rita Grewal] if needed) to determine if a BAA is required, see VHA Directive 1605.05, Business Associate Agreements, Appendix A, (https://www.va.gov/vhapublications/ViewPublication.asp?pub_ID=9178)).

If it is determined that a BAA is required, the CO must, in eCMS, insert the BAA Document below as a "Clause" into Section D - CONTRACT DOCUMENTS, EXHIBITS, OR ATTACHMENTS of the solicitation manually by performing the following instructions:

1. Open the below embedded "VA Subcontractor OIT Business Associate Agreement" Template file, insert a brief description of the services involved in the effort within the "Scope" Section, and the VA Program Manager information in the VA Signature block at the end of the form, and replacing any other **<RED TEXT>** within the template. Once complete, save the "Business Associate Agreement" file to your computer.
2. Create a solicitation document in eCMS
3. Click on the 'Content Manager' link and highlight Section D, Contract Documents, Exhibits, or Attachments.
4. Click on the "Insert" tab in the top left corner to insert an "External File" after the selected clause.
5. Upload the "Business Associate Agreement" file you saved to your computer.

The Business Associate Agreement file is the text of the eCMS VHA Clause 1605.05, tailored for the individual effort, and is essentially the Business Associate Agreement language itself, and needs to be seen by the bidders in the solicitation (if a BAA is required).

DRAFT

VA Subcontractor OIT
Business Associate Ag

☐ BAA required **for a Veterans Health Administration (VHA) Contract?**

If the answer to Question 4 of the Security Checklist is a "yes" and the Contractor will provide a service, function, or activity **to VHA or on behalf of VHA**, then it must be determined if protected health information (PHI) is disclosed or accessed and if a BAA is required. The "Decision Tree for Business Associate Agreements" should be used by the requiring activity (with help from their Privacy Officer if needed [the VHA Privacy Service -Stephania Griffin/ Andrea Wilson can advise] to determine if a BAA is required, see VHA Directive 1605.05, Business Associate Agreements, Appendix A, (https://www.va.gov/vhapublications/ViewPublication.asp?pub_ID=9178).

If it is determined that a BAA is required, the CO must, in eCMS, insert the BAA Document below as a "Clause" into Section D - CONTRACT DOCUMENTS, EXHIBITS, OR ATTACHMENTS of the solicitation manually by performing the following instructions:

1. Open the below embedded "VHA Business Associate Agreement" Template file, insert a brief description of the services involved in the effort within the "Scope" Section, VA Organization Information, and the information in the VA Signature block at the end of the form, and replacing any other **<RED TEXT>** within the template. Once complete, save the "Business Associate Agreement" file to your computer.
2. Create a solicitation document in eCMS
3. Click on the 'Content Manager' link and highlight Section D, Contract Documents, Exhibits, or Attachments.
4. Click on the "Insert" tab in the top left corner to insert an "External File" after the selected clause.
5. Upload the "Business Associate Agreement" file you saved to your computer.

The Business Associate Agreement file is the text of the eCMS VHA Clause 1605.05, tailored for the individual effort, and is essentially the Business Associate Agreement language itself, and needs to be seen by the bidders in the solicitation (if a BAA is required).

VHA Business
Associate Agreement

☐ Other _____
☐ Other _____

DRAFT

FOR TAC USE ONLY---SECURITY RELATED GUIDANCE

☒ ***(Always Checked for Services)*** Addendum B Security Requirement guidance to CO within Addendum B, Section B9 Training, Para. a) Sub Para. 2,

Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system access ***[to be defined by the VA program official and provided to the contracting officer for inclusion in the solicitation document – e.g., any role-based information security training required in accordance with NIST Special Publication 800-16, Information Technology Security Training Requirements.]***

☒ ***(Always Checked for Services)*** Contractor Rules of Behavior-Appendix D in Handbook 6500.6 – ***(CO to add to solicitation, CO to ensure Contractor signs and acknowledges (electronically through VA Privacy and Information Security Awareness and Rules of Behavior course TMS 2.0 #VA 10176) understanding of and responsibilities for compliance with the Contractor Rules of Behavior, Appendix D relating to access to VA information and information systems.)***

ADDITIONAL NOTES TO PREPARER

1. ***Run Spell Check and Grammar Check in document for final review. Simple and easy tool to utilize and benefit from.***
2. ***When listing/itemizing points, keep the outline consistent (use appropriate number or letter, versus a bullet).***
3. ***If deliverables need to be submitted in draft form, timeframes must be stated. Reference example provided in the table above.***
4. ***Other submissions may be required but not held to draft/comment/final submissions. For example, monthly status reports are due 5 days after the conclusion of the reporting period (end of month).***
5. ***Customer must identify which deliverables continue if option years are exercised. Not all deliverables would necessarily repeat. Certain deliverables are final in the base year.***
6. ***Do not put deliverable due dates in any PWS task narrative or in the "Deliverables:" list at the bottom of each task narrative. Rather, include timeframes/due dates in "Schedule for Deliverables" table in the "Notes to the Contracting Officer" Section above. Also ensure customer deliverables are detailed in the narrative of the task to include format and content requirements.***

DRAFT

7. *Ensure deliverables in tasks match deliverables in table.*
8. *If VIP applies, ensure deliverables are delivered in 3 month increments or less within an agile framework.*
9. *Deliverable due dates should be in terms of number of days after award or based on an event.*
10. *If for some reason the deliverable must be submitted in hard copy or on CD, be sure to specify the requirement within the line item. Also, in this case identify number of copies and mailing address.*
11. *Each deliverable line item must cite inspection and acceptance criteria; Inspection: Origin or Destination; Acceptance: Origin or Destination (most likely destination on both).*
12. *Update the Table of Contents by hitting F9.*

DRAFT